

Threat Prioritization Candidate Risking Procedure

Revision

Version 4
8/26/26 7:11 PM

Author

Charles Wilson

Abstract

This document describes the procedure used to perform the threat candidate risking activity described in the **AVCDL** ^[1] **Threat Prioritization Plan** ^[2] secondary document.

Group / Owner

Security / Security Architect

Motivation

This document is motivated by the need to have formal processes in place regarding the disposition of cybersecurity-related threats in the context of the development of safety-critical, cyber-physical systems.

Note: Within the context of this document, the terms **security** and **cybersecurity** are used interchangeably. It is presumed that the term **security** is being used in reference to **cybersecurity** and not **physical security**.

License

This work was created by **Torc Robotics** and is licensed under the **Creative Commons Attribution-Share Alike (CC BY-SA-4.0)** License.

<https://creativecommons.org/licenses/by/4.0/legalcode>

Audience

The audience of this document is the practitioner who will be conducting the threat candidate risking activity within the threat prioritization process.

Completeness of Output

Since threat candidate risking is an as-is analysis, it is critical to ensure that the information gathered is as accurate and complete as possible. As with any cybersecurity assessment, it is not the place of the SME to make assumptions on the part of engineering. All information should be sourced from and confirmed by the owner of the element under consideration.

When information is not available for either a given section of the template or parts thereof, this should be noted. Major omissions should be recorded in the cybersecurity risk register.

Disposition of Output

The output of this activity is used as input to the **threat candidate slicing** activity.

Once completed, the generated report should be managed in the organization's document management system (DMS) as a document of record.

Entry Criteria

This document assumes that the reader understands the purpose of threat candidate risking. Further, that the reader has read and understood the AVCDL **Threat Prioritization Plan** secondary and **Threat Prioritization – Candidate Ranking Procedure** ^[3] tertiary documents.

Prerequisites – Risk SME

Qualifications

It is required that the Risk SME is both a qualified and trained Risk SME with expertise in the risk domain of the element under consideration.

Note: The specific qualifications and training of Risk SMEs necessary to assert expertise in providing accurate information regarding the risk domain aspects of the element under consideration is outside the scope of this document.

Note: The Risk group is responsible for determining and making available the appropriate SME for the determination of risk impact threat candidates within the element under consideration.

Knowledge

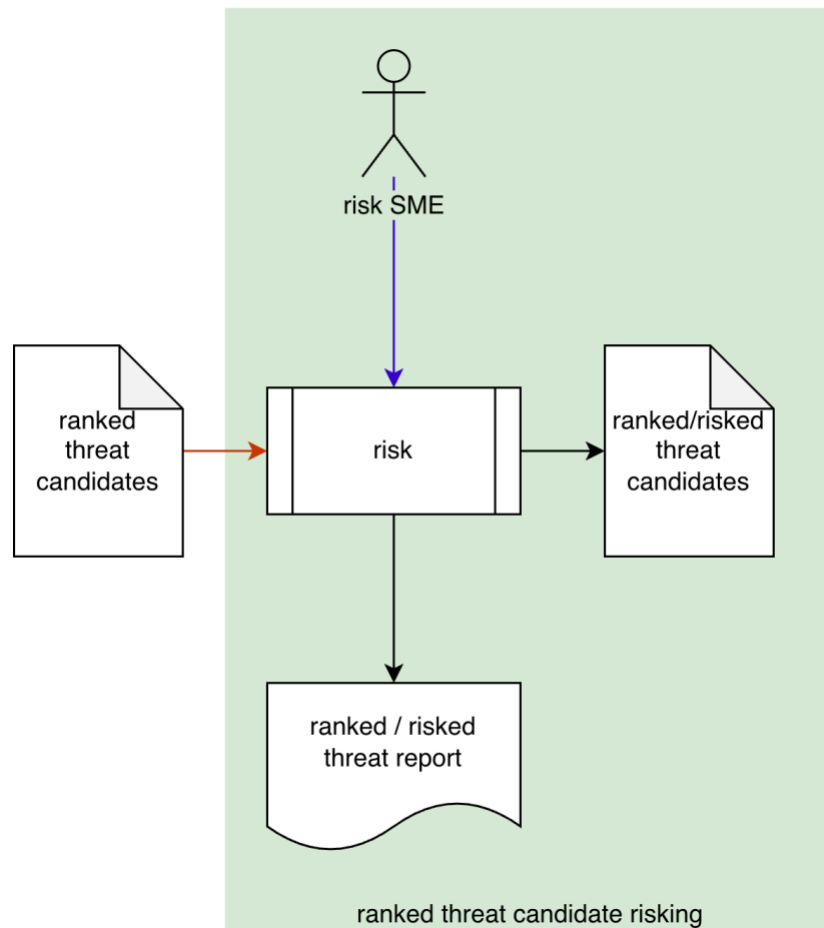
It is required that the risk SME understands the purpose of threat candidate risking.

Prerequisites – Input Materials

It is required that the risk SME acquire any documentation relevant to the threat candidates under consideration necessary to complete the procedure.

Candidate Risking Activity

The workflow diagram for the **threat candidate risking** activity of the **Threat Prioritization Plan** is shown below.



The **risk SME** takes the **ranked threat candidates** and conducts a risking on them to establish the impact of each. This produces a list of **ranked/risked threat candidates**. A **ranked/risked threat report** is generated.

Note: A standard rubric should be used for determination of the threat impact.

Note: The specifics of the ranked / risked threat report are discussed in the **Ranked / Risked Threat Report** ^[10] secondary document.

Methodology

The recommended methodology for this activity is as follows:

1. Select an impact rubric
2. Where appropriate, encode rubric quantization bands
3. Where appropriate, encode domain quantization bands
4. Enumerate the threat candidates with minimal necessary details
5. Determine and record the rubric value and metadata for each threat candidate
6. Provide notes where appropriate

Discussion

This section provides additional information to assist in performing this activity.

Risk Domain

As discussed in the AVCDL primary document section **3.4.4. Risk**, there are multiple risk domains which may need to be taken into consideration when evaluating cybersecurity-based threats. When this is the case, it is assumed that each risk domain provides a separate treatment of the ranked threat candidates.

Note: The results of multiple risk domain consideration will be addressed in the risk domain consolidation activity of the threat prioritization process.

Impact Rubric

The rubric used to determine a threat candidate's likelihood should be appropriate to the nature of the threat.

Some common rubrics are:

Rubric		Application
ISO 26262 ^[4]	Road vehicles – Functional safety – Part 3: Concept phase	Safety - automotive
ISO 14971 ^[5]	Medical devices – Application of risk management to medical devices	Safety - medical
FIPS 199 ^[6]	Standards for Security Categorization of Federal Information and Information Systems	IT

A more general rubric is presented in tables **H-3** of **NIST SP 800-30 Guide for Conducting Risk Assessments** ^[7].

Impact (ISO 26262 Rubric)

The focus of **ISO 26262** is road vehicle functional safety.

The following table shows how ISO 26262 defines its impact values.

	impact
S1	light injuries
	moderate injuries
S2	severe and life-threatening injuries (survival probable)
S3	life-threatening injuries (survival uncertain)
	fatal injuries

Impact (ISO 14971 Rubric)

The focus of **ISO 14971** is medical device risk management.

The following table shows how ISO 14971 defines its impact values.

	impact
negligible	inconvenience or temporary discomfort
minor	temporary injury or impairment, not requiring professional medical intervention
serious	injury or impairment requiring professional medical intervention
critical	permanent impairment or life-threatening injury
catastrophic	death

Impact (FIPS 199 Rubric)

The focus of **FIPS 199** is IT cybersecurity.

The following table shows how FIPS 199 defines its impact values.

	impact
low	limited adverse effect
moderate	serious adverse effect
high	severe or catastrophic adverse effect

Note: FIPS 199 sub-divides the impact (security categorization) into three components (confidentiality, integrity, and availability), each of which is determined separately.

Impact (SP 800-30 Rubric)

The focus of **NIST SP 800-30** is general cybersecurity. It can be applied within any risk domain.

Unlike rubrics that only provide a text value, the impact rubric provided by **SP 800-30** provides numeric ranges for the values that can be used to visualize the distribution of the values and also to generate an overall risk of the threat candidate.

Note: The way SP 800-30 generates an overall risk value will be examined in the threat prioritization slicing activity document.

A visualization of the SP 800-30 impact values and their ranges is shown below.

800-30 score	0	0+	10	20	30	40	50	60	70	80	90	100
800-30 rating	none	very low	low	moderate						high	very high	

Note: For the purposes of this activity, only the impact values will be needed.

The following table shows how SP 800-30 defines its impact values.

	impact
very low	a negligible adverse effect
low	a limited adverse effect
moderate	a serious adverse effect
high	a severe or catastrophic adverse effect
very high	multiple severe or catastrophic adverse effects

Impact Rubric Comparison

The following table is provided to give a sense of how the terminology used by the various rubrics compare when they are aligned by impact severity.

FIPS 199	ISO 14971	ISO 26262	NIST 800-30	ISO/SAE 21434
none	none	none	none	0
low	negligible	S1	very low	1
moderate	minor		low	2
	serious	S2	moderate	3
high	critical	S3	high	4
	catastrophic		very high	5

Note: Shown here is also a domain-specified (ISO/SAE 21434 automotive) value set for impact. This standard does not provide definitions for the values.

Note: As was the case for the candidate ranking activity, a value of none has been added to aid automation.

When using domain mapping where the impact rubric does not have the same granularity, it may be necessary to identify the appropriate mapping based on additional information provided by the rubric itself. For example, although ISO 26262's impact value of **S1** includes both **light** and **moderate injuries**, if these can be differentiated, an appropriate value for a domain mapping into ISO/SAE 21434 of either **1** or **2** is possible.

Threat Candidate Risking Template

The threat candidate risking may be documented using the **AVCDL threat candidate risking template** Microsoft Excel workbook [\[9\]](#).

Note: Other forms of documentation are permissible so long as they provide the information laid out in this document.

There workbook contains the following sheets:

- [Cover sheet](#)
- [Revision history](#)
- [Reference documents](#)
- [Risking](#)
- [Labels](#)
- [Legend](#)

These will be addressed in turn.

Duplication of Rows in the Various Sheets

When there is the need to add rows to the various sheets of the workbook, be sure to duplicate an existing row. This is because validation checks and inter-sheet lookups may be attached to some of the cells which enables the use of dropdown lists and auto-population.

Cover Sheet

The **cover sheet** of the workbook is shown below:

Threat Candidate Risking									
Risk SME	Risk SME								
Risk Domain	Risk Domain								
Impact Rubric	Rubric								
Date	27-Aug-2000								
Revision	1								

Fields to be completed are shown in **red**.

Risk SME

This is the risk domain subject matter expert creating the threat candidate risking list.

Risk Domain

This is the risk domain being applied to the activity (**safety, finance, operations, privacy, ...**).

Impact Rubric

This is the name of the rubric used to determine the threat candidate's impact.

Date

This is the date when the document was created or updated. The date should be updated whenever the document is updated.

Revision

This is the revision number of the document. The revision number is a monotonic and increasing integer, starting at 1. It should be incremented every time the document is updated.

Revision History

The **revision history** sheet of the workbook is shown below:

Revision History		
Revision	Author	Description
1		initial revision

Revision

The **revision** corresponds to that listed on the cover sheet.

Author

The **author** corresponds to the cybersecurity SME listed on the cover sheet.

Description

This is a brief description of changes made to the workbook since it was last updated.

Reference Documents

Note: These references are those necessary for the creation of the threat candidate risking list.

Note: References to information for the rubric used should be included.

These entries are shown in **red**.

The **references** sheet of the workbook is shown below:

Reference Documents		
Name	Description	Location
rubric name	rubric description	rubric reference URL
domain mapping name	domain mapping reference description	domain mapping reference URL

Name

This is the name of the document being referenced.

Description

This is a brief description of the document being referenced.

Note: In cases where the reference material is expressed in the form other than a document (for example, a web page), this should be noted.

Location

This is the location of the document being referenced. It may be a physical location or a URL.

Risking

The **risking** sheet of the workbook is shown below:

Risking						
candidate ID	description	element	worst case	rubric value	domain value	notes

Candidate ID

This is the unique ID of the threat candidate.

Note: This value should be copied from the candidate ranking output providing input to this activity.

Description

This a description of the threat candidate.

Note: This value should be copied from the candidate ranking output providing input to this activity.

Element

This is the name of the element within the system where the threat candidate originates.

Note: This value should be copied from the candidate ranking output providing input to this activity.

Worst Case

This is a worst case scenario assuming the threat is realized.

Note: This value should be copied from the candidate ranking output providing input to this activity.

Rubric Value

This is value determined by the likelihood rubric. The values is selected from a dropdown list.

Note: The dropdown list is auto-populated based on information in the **labels** sheet.

Domain Value

This is domain-mapped value of the likelihood value. The values is selected from a dropdown list.

Note: The dropdown list is auto-populated based on information in the **labels** sheet.

Notes

This is a general notes field.

Labels

This sheet provides the rubric value and domain mapping labels.

The **rubric quantization** sheet of the workbook is shown below:

Labels			
rubric label	domain label	description	notes
none	none	used to enable automation	

Note: A true zero (none) entry is pre-populated in order to support automation.

Rubric Label

This is the list of rubric values in ascending order.

Note: This column is used to populate the **rubric value** field dropdown on the **risking** sheet.

Note: Where the rubric does not use a full set of five values, it is recommended to replicate the value as indicated in the [Impact Rubric Comparison](#) table.

Domain Label

This is the list of mapped domain values in ascending order.

Note: This column is used to populate the **domain value** field dropdown on the **risking** sheet.

Description

This is the description of the rubric value.

Notes

This is a general notes field.

Legend

Note: This workbook does not use the legend sheet.

Exit Criteria

This procedure is considered complete once the **ranked threat candidates** list has been generated.

Note: This activity does not generate any materials used as documents of record.

References

1. **AVCDL** (AVCDL primary document)
2. **Theat Prioritization Plan** (AVCDL secondary document)
3. **Threat Prioritization – Candidate Ranking Procedure** (AVCDL tertiary document)
4. **ISO 26262-3:2018 Road vehicles – Functional safety – Part 3: Concept phase**
<https://www.iso.org/standard/68385.html>
5. **ISO 14971:2019 Medical devices – Application of risk management to medical devices**
<https://www.iso.org/standard/72704.html>
6. **NIST FIPS 199 Standards for Security Categorization of Federal Information and Information Systems**
<https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.199.pdf>
7. **NIST SP 800-30 r1 – Guide to Conducting Risk Assessments**
<http://dx.doi.org/10.6028/NIST.SP.800-30r1>
8. **ISO/SAE 21434:2021 Road vehicles – Cybersecurity engineering**
<https://www.iso.org/standard/70918.html>
9. **AVCDL threat candidate risking template** (AVCDL template)
10. **Ranked / Risked Threat Report** (AVCDL secondary document)